Threat Model and Hardening Plan

Scope: A small web application with user registration/login, a user profile, a public content feed, an admin dashboard, and a cloud-hosted database. The model uses STRIDE, Microsoft's threat taxonomy covering Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. [web:2][web:6]

1. Threat-Model Diagram

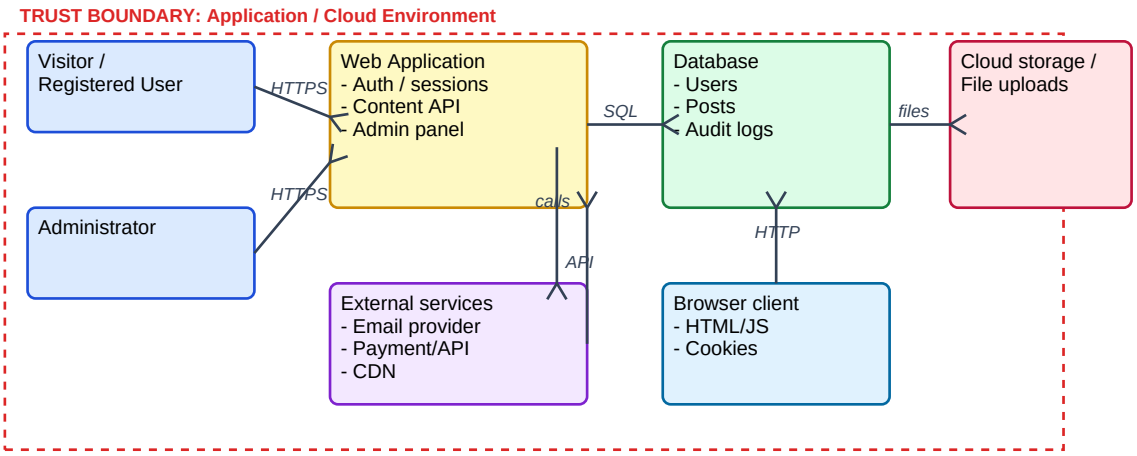

Figure 1: Users interact with the web application over HTTPS; the application reads and writes to the database, calls external services, and stores uploaded files. The red dashed line is the primary trust boundary: data crossing it must be authenticated, authorized, validated, and logged.

2. Assets and Abuse Cases

Asset	Owner / location	Why it matters
User account credentials	Database / authentication service	Compromise enables account takeover and further abuse.
Session tokens and cookies	Browser and server	Theft or reuse can impersonate legitimate users.
Personal data: name, email, profile	Database	Disclosure creates privacy, legal, and reputational impact.
User-generated posts and uploads	Database / object storage	Can be used to host malware, phishing, or malicious scripts.
Admin dashboard	Application	Compromise can expose or alter all user data.
Database	Cloud environment	Central store of sensitive application data.
Availability and reputation	Hosting provider / application	Outage or defacement reduces user trust and revenue.

3. STRIDE Risk Register

Likelihood and impact are rated Low (1), Medium (2), or High (3). Risk score = likelihood × impact. Priorities: Critical = 8–9, High = 6, Medium = 3–4, Low = 1–2.

ID	STRIDE category	Threat / abuse case	Likelihood	Impact	Score	Priority
R1	Spoofing	Credential stuffing and password spraying against login using leaked passwords.	High (3)	High (3)	9	Critical
R2	Elevation of Privilege	Missing server-side authorization lets a normal user call admin endpoints or edit another user's record (IDOR/BOLA).	High (3)	High (3)	9	Critical
R3	Tampering	SQL injection in search, login, or content filters modifies or extracts database records.	Medium (2)	High (3)	6	High
R4	Information Disclosure	Stored XSS in a post or profile injects script that steals session cookies from other users.	Medium (2)	High (3)	6	High
R5	Information Disclosure	Unrestricted file upload allows an attacker to upload an HTML/SVG file that executes script or exposes internal files.	Medium (2)	High (3)	6	High
R6	Spoofing	Session cookie is not marked Secure/HttpOnly/SameSite, enabling theft through XSS or CSRF.	Medium (2)	High (3)	6	High
R7	Tampering	Client-side price, role, or user-ID fields are trusted and can be modified in requests.	Medium (2)	High (3)	6	High
R8	Denial of Service	No rate limiting on login, password reset, search, or upload endpoints enables resource exhaustion.	High (3)	Medium (2)	6	High
R9	Repudiation	Sensitive actions lack audit logs, so an attacker or insider can deny changes.	Medium (2)	Medium (2)	4	Medium
R10	Information Disclosure	Verbose errors, debug endpoints, source-control files, or permissive CORS leak technical details.	Medium (2)	Medium (2)	4	Medium
R11	Tampering / Elevation	Outdated frameworks or dependencies contain known exploitable vulnerabilities.	Medium (2)	Medium (2)	4	Medium
R12	Information Disclosure	Passwords or password-reset tokens stored or transmitted insecurely.	Low (1)	High (3)	3	Medium

STRIDE definitions follow Microsoft's taxonomy: spoofing is false identity claims, tampering is unauthorized modification, repudiation is denial of an action, information disclosure is unauthorized viewing, denial of service degrades availability, and elevation of privilege gains unauthorized rights. [web:1][web:8]

4. Prioritized Hardening Plan

Priority	Control	Addresses	Implementation guidance
P0 — Immediate	Enforce server-side authorization	R2, R7	Check the authenticated user's role and ownership on every request; never rely on hidden fields, client-side checks, or predictable IDs. Use centralized authorization middleware and automated tests for IDOR/BOLA.
P0 — Immediate	Secure authentication and sessions	R1, R6, R12	Use a vetted authentication framework; hash passwords with Argon2id or bcrypt; enforce MFA for admins; set cookies with Secure, HttpOnly, and SameSite attributes; rotate session IDs after login and logout.
P1 — 30 days	Prevent injection	R3	Use parameterized queries or an ORM for every database call; validate input by type, length, and allow-list; avoid dynamic SQL and shell commands.
P1 — 30 days	Escape output and apply CSP	R4	Use context-aware output encoding, a strict Content-Security-Policy, and safe file rendering. Disable inline scripts where practical.
P1 — 30 days	Harden uploads	R5	Store uploads outside the web root or in object storage; validate file type and size; regenerate filenames; serve downloads with Content-Disposition: attachment and a restrictive content type; scan for malware.
P1 — 30 days	Add rate limiting and monitoring	R8	Apply per-IP and per-account limits to login, reset, registration, search, and uploads; add lockout/backoff; alert on spikes and repeated failures.
P2 — 60 days	Implement audit logging	R9	Record login, logout, permission changes, data exports, admin actions, and failed authorizations with timestamp, actor, source IP, and action. Protect logs from modification and restrict access.
P2 — 60 days	Reduce configuration exposure	R10	Disable debug mode in production; return generic errors; remove source-control and backup files; restrict CORS to trusted origins; set security headers including HSTS, X-Content-Type-Options, and Referrer-Policy.
P2 — 60 days	Manage dependencies	R11	Maintain a software bill of materials; scan dependencies in CI; patch high/critical findings promptly; pin versions and review changes.
P3 — Ongoing	Encrypt and protect data	R12	Use TLS 1.2+ everywhere; encrypt sensitive fields at rest where appropriate; protect secrets in a managed secret store; limit database permissions to least privilege.

5. Acceptance Checklist

■ Diagram shows users, data stores, trust boundaries, and external dependencies.

■ Threats are identified using STRIDE across authentication, authorization, input handling, uploads, availability, and logging.

■ Each risk has likelihood, impact, score, and priority.

■ Critical authorization and authentication issues are scheduled first.

■ Controls are specific, testable, and proportionate to a small application.

■ The plan includes verification steps and ongoing maintenance.

6. Verification and Evidence

Evidence should be collected only in an authorized lab or against systems you own. Suitable proof includes screenshots of authorization tests, dependency-scan results, security-header checks, rate-limit test results, and a before/after configuration diff. OWASP identifies insecure design, injection, cryptographic failures, security misconfiguration, and vulnerable components as major web-application risk areas, which aligns with the priorities above. [web:3][web:9][web:15]